

Ransomware Extortion in Healthcare

“An evidence-based analysis of the HSE (2021) and Change Healthcare (2024) incidents”

Name: Khalid Bakhshi

PICT3011 Cyber Security in Practice

Investigation Scope and Preliminary Finding

Investigation Scope	Scope and preliminary finding
Attack category	Ransomware extortion affecting healthcare organisations
Incidents examined	HSE, Ireland, 2021: Conti ransomware Change Healthcare, United States, 2024: ALPHV/BlackCat ransomware
Evidence base	Official incident reports, congressional testimony, government guidance and organizational disclosures
Analytical approach	Manual and one-shot LLM attack trees were compared and synthesized for each incident before developing a cross incident model
Preliminary finding	Different initial access routes converged on enterprise expansion, encryption, data theft and extortion
Key finding	Several mechanisms remain unknown or redacted, so the attack tree represents a preliminary model

Investigation question: Which recurring attack pathways and control weaknesses should healthcare organisations address first?

Healthcare Ransomware Extortion

Ransomware extortion: involves attackers encrypting systems, stealing sensitive data, or using both methods to pressure an organisation into pay a ransom.

Extortion pathway	Attacker actions	Potential business impact
Availability pressure	Deploy ransomware and encrypt systems	Services become unavailable, disrupting care, claims, pharmacy services and payments
Confidentiality pressure	Locate, copy, and exfiltrate sensitive data, then threaten disclosure	Privacy harm, breach notification obligations, reputational damage and additional extortion pressure

Critical assets: patient information, clinical and administrative systems, claims and payment platforms, privileged accounts, backup infrastructure and dependent healthcare services

Both investigation incidents involved encryption and stolen data pressure, representing double extortion.

Investigation and Evidence Method

Stage	What I did	Purpose
1. Evidence audit	Extracted attacker actions, affected assets, control weaknesses and evidentiary gaps from each source	Separated confirmed evidence from assumptions and threat-intelligence hypotheses
2. Manual modelling	Independently constructed an attack tree for each incident using explicit AND and OR gates	Produced an evidence-based model before viewing the LLM result
3. LLM generation	Used one prompt with ChatGPT for each incident and retained the original output	Created an independent LLM model for comparison
4. Comparison and synthesis	Compared the manual and LLM trees, removed unsupported paths and incorporated useful differences	Produced a case-synthesised tree for each incident and a final cross-incident model

Evidence Status Legend

Status	Meaning	Colour
R-H	Reported evidence, high confidence	Green
I-M	Evidence based inference, medium confidence	Amber
U	Unknown or redacted	Red

Only attacker actions appear inside the tree. Control weaknesses appear as side annotations, and undisclosed mechanisms remain marked as unknown

HSE Conti Ransomware Incident, 2021

Attack Stage	Publicly reported evidence	Status
Initial access <i>PwC (2021, pp. 29, 45)</i>	Attackers sent a phishing email containing a malicious excel attachment and established a foothold on the patient-zero workstation	R-H
Enterprise expansion <i>PwC (2021, pp. 29, 45, 54)</i>	Attacker conducted Active Directory reconnaissance, compromise at least 33 privileged accounts and moved through connected HSE and hospital environments	R-H
Coercive impact <i>PwC (2021, pp. 29, 45, 55)</i>	Attackers deployed Conti across the HSE and six hospitals. Encryption affected more than 2800 servers and 3500 workstations	R-H
Data and extortion <i>PwC (2021, pp. 1, 54–55)</i>	Attackers accessed and copied files, published authentic samples and demanded payment for decryption and non publication	R-H / I-M

Critical assets: clinical and administrative systems, patient and organizational data, Active Directory, privileged accounts servers, workstations and backup infrastructure.

Business impact: widespread healthcare-service disruption, loss of system availability, recovery costs and potential privacy harm.

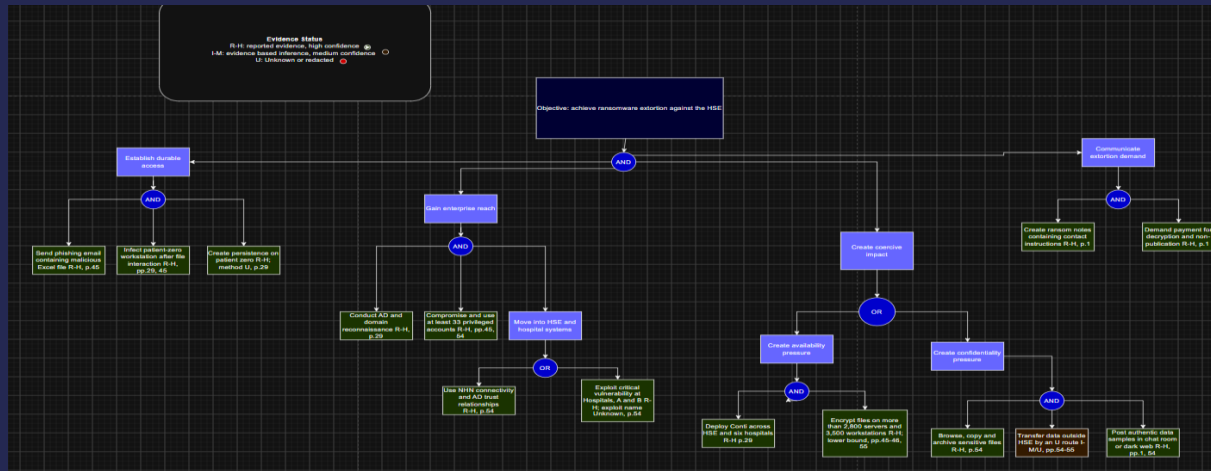
EVIDENCE GAPS:

U: Exact persistence mechanism was not disclosed

U: The vulnerability exploited at Hospitals A and B was redacted

I-M/U: Investigators could not conclusively establish the complete data-exfiltration route or volume

HSE Manual and LLM Attack Trees



Manual attack tree



Original ChatGPT attack tree

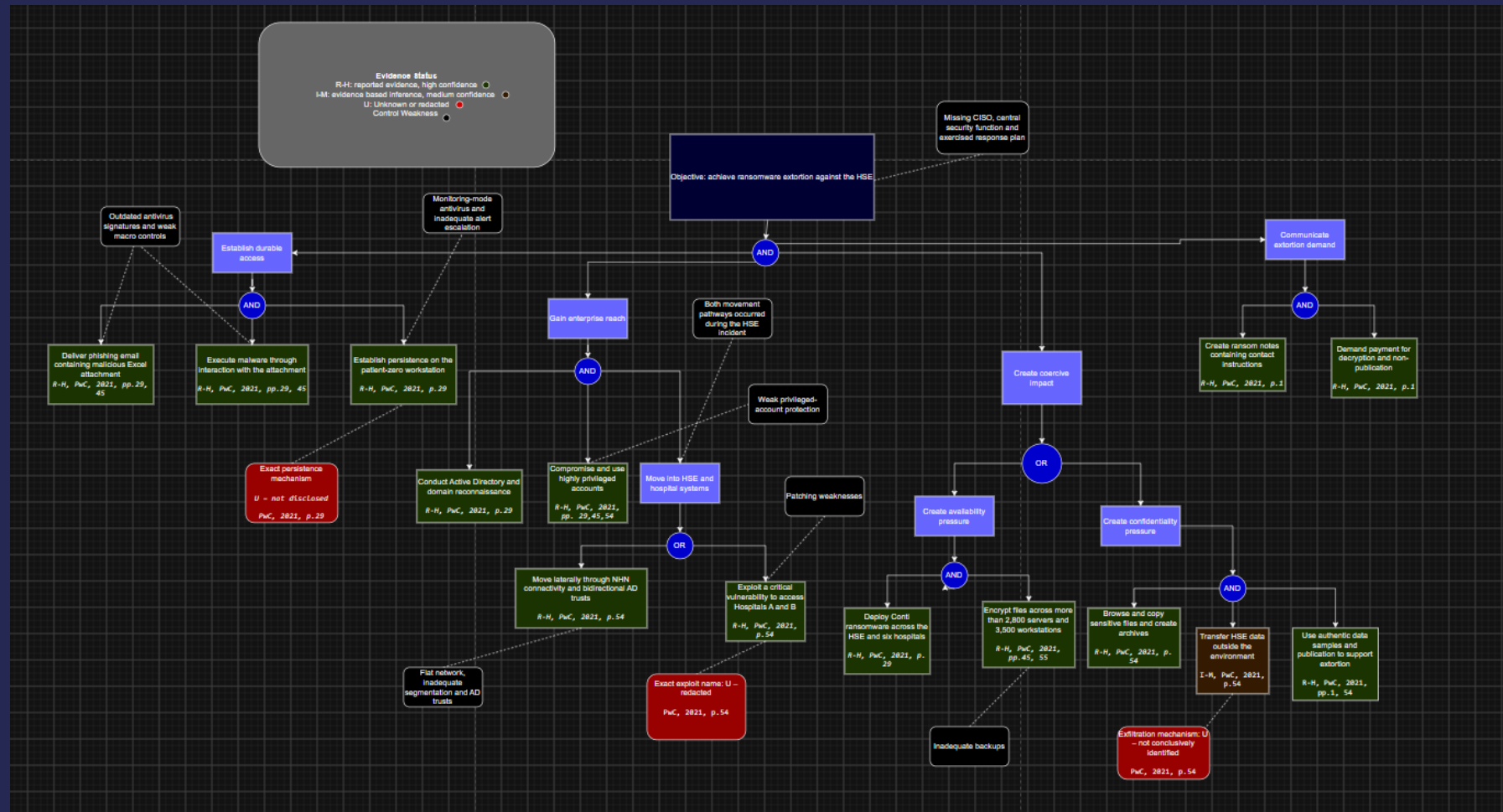
Full models are provided in Appendices A and B.

HSE Manual and LLM Attack Tree Comparison

Comparison area	Manual attack tree	ChatGPT Tree
Overall structure	Separates access, enterprise reach, coercive impact and communication of the demand	Captures access, expansion and extortion pressure but places the ransom demand under encryption
Evidence Handling	Provides report pages and evidence status beside the leaves	Provides a concise pathway but lacks consistent page references and evidence statuses
Attacker actions	Contains only actions performed by the attacker	Includes “user opens attachment” which describes a victim action
Uncertainty	Marks persistence, the hospital exploit and exfiltration details unknown or inferred	Does not clearly display these evidence gaps
Main strength	Detailed, traceable and supported by the PwC report	Simple structure that clearly presents encryption and stolen data pressure
Main limitation	More complex and visually dense	Oversimplifies the evidence and presents some uncertain mechanisms too confidently

Synthesis decision: Retained the LLM tree’s clear distinction between encryption and stolen data pressure, while applying the manual tree’s evidence citations, attacker action rule and uncertainty.

HSE Case Synthesised Attack Tree



Simplified presentation view — full model provided in Appendix C.

HSE Case Synthesised Attack Tree Analysis

Key interpretation

The root uses **AND** because the attacker required access, enterprise reach, coercive impact and communication of the demand.

The impact branch uses **OR** because encryption or stolen-data disclosure could create extortion pressure. Evidence indicates that both occurred.

Unknown persistence, vulnerability and exfiltration mechanisms remain marked **U** rather than assumed.

Key finding

Multiple weaknesses in prevention, detection, privileged access, network segmentation and recovery contributed to the incident

Change Healthcare Ransomware Incident, 2024

Stage	Publicly reported evidence	Status
Initial access	On 12 February 2024, attackers used compromised credentials to access a Citrix portal that lacked MFA	R-H
Enterprise expansion	The attackers move laterally and exfiltrated data before deploying ransomware. The detailed mechanisms remain undisclosed.	R-H / U
Coercive impact	On 21 February, the attackers deployed ransomware. Stolen personal and health information provided additional disclosure pressure.	R-H
Extortion and response	UnitedHealth Group confirmed that it paid the ransom. Change Healthcare disconnected affected systems to contain the attack.	R-H

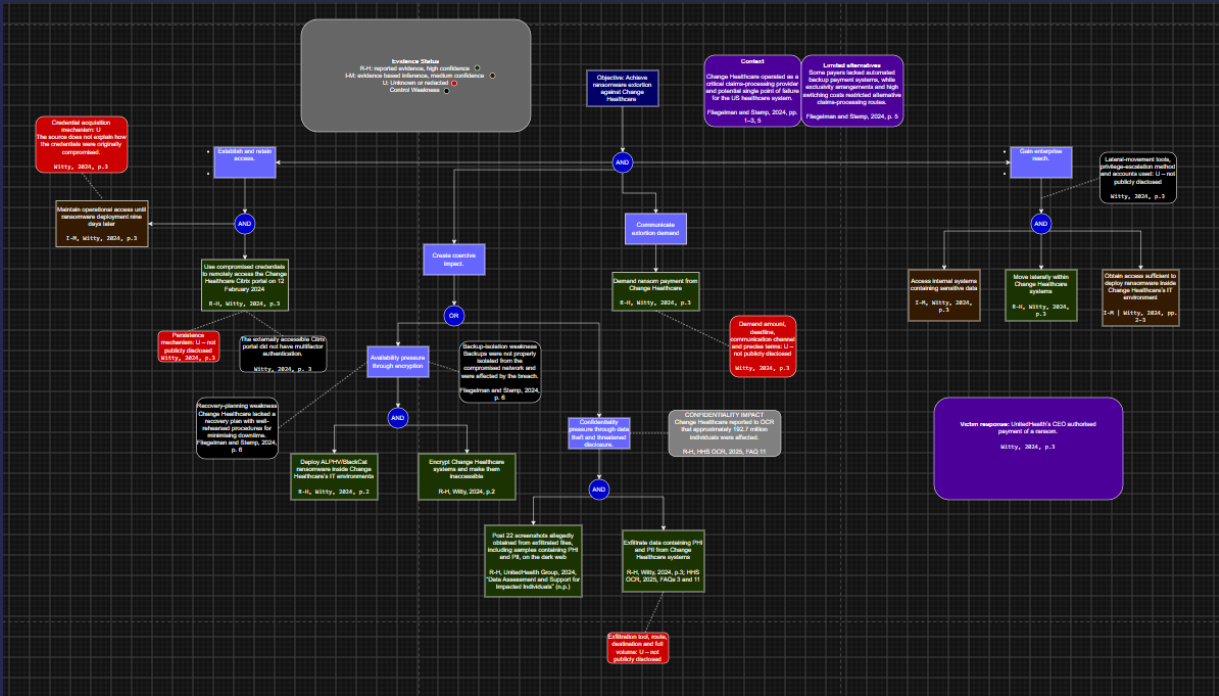
Change Healthcare Ransomware Incident, 2024

Assets and Consequences

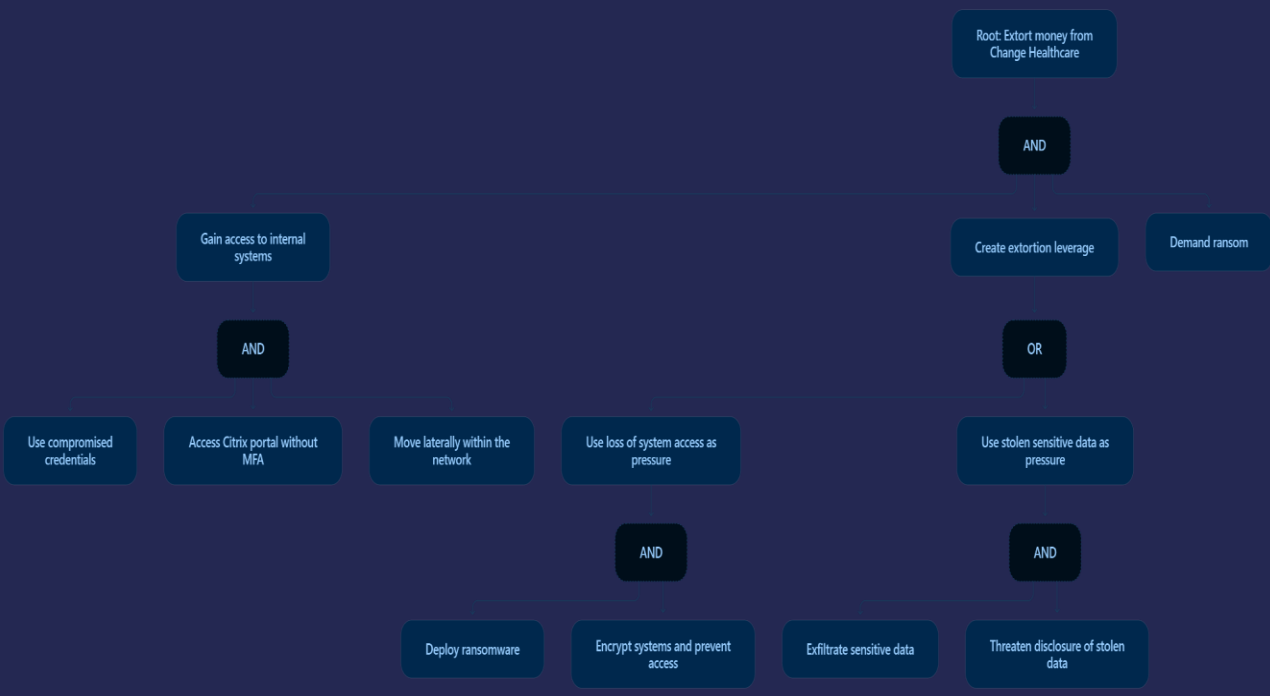
Critical assets	Business consequences	Evidence gaps
Claims processing and payment services	Nationwide disruption to healthcare payment workflows	Credential acquisition method: U
Pharmacy transaction services	Cash flow pressure on healthcare providers	Lateral movement tools and techniques: U
Healthcare data exchange systems	Loss of system availability	Detailed data-exfiltration route: U
Personal and protected health information	Privacy, notification and regulatory exposure	

Preliminary finding: There was no MFA, which allowed the attacker to use the compromised credentials to gain remote access

Change Healthcare Manual and LLM Tree Comparison



Manual attack tree



Original ChatGPT attack tree

Simplified presentation view — full models provided in Appendix D and E

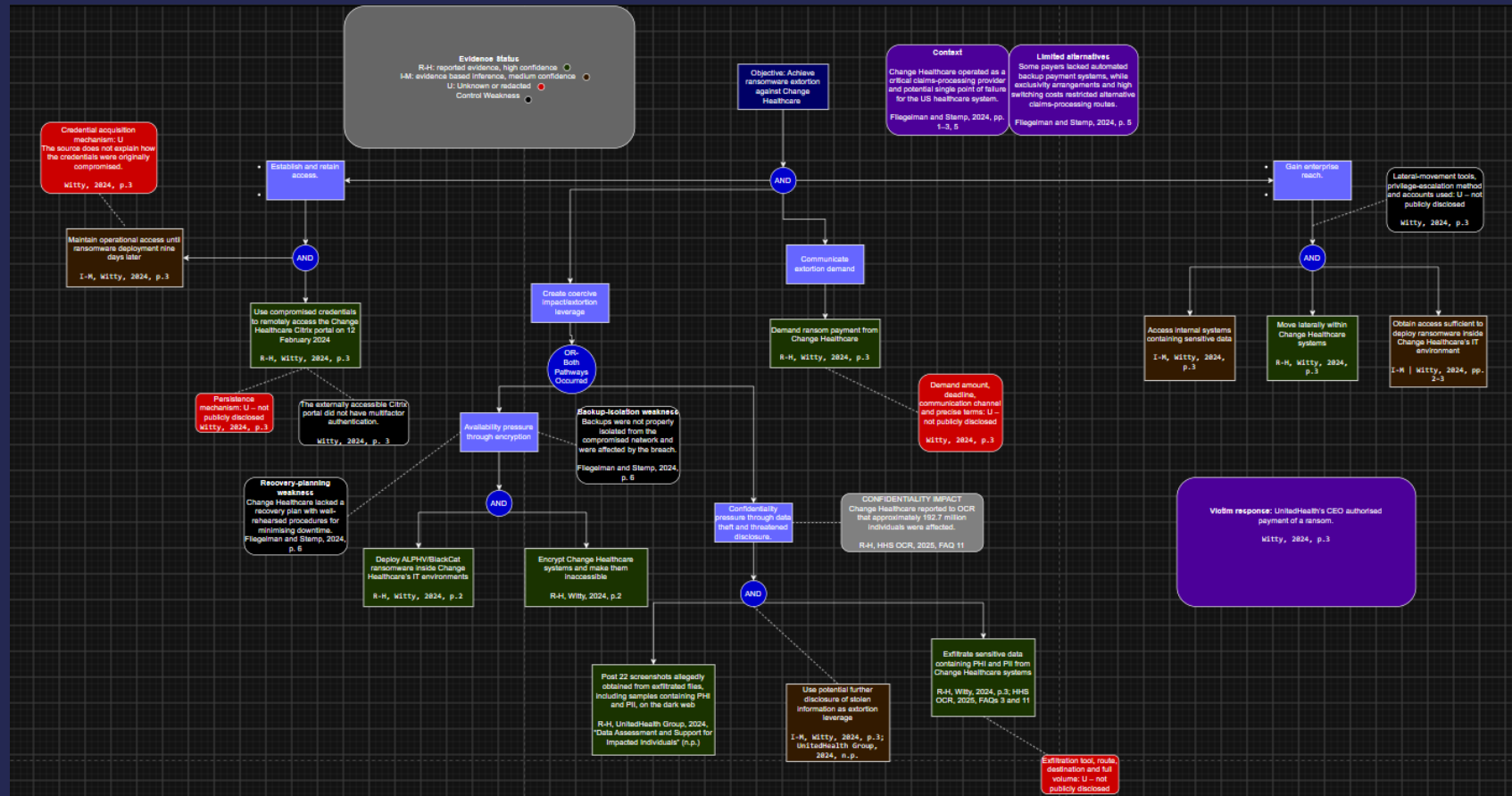
Change Healthcare Manual and LLM Attack Tree Comparison

Criterion	Manual Tree	ChatGPT Tree
Evidence	Includes sources, page numbers and evidence status beside each leaf	No evidence status inside the tree
Structure	Separate initial access, enterprise expansion, coercive impact and demand	Provides a clear overview but combines access and lateral movement
Control weaknesses	Places the absence of MFA outside the tree as a control weakness	Combines the attacker action and absence of MFA in one node
Uncertainty	Marks credential acquisition and undisclosed mechanisms as U	Avoids assuming phishing but does not visibly mark every evidence gap
Main limitation	Detailed structure makes the diagram visually dense	Simplifies the incident and omits several post-access mechanisms

Synthesis decision:

Used the manual tree as the evidence base. Kept ChatGPT's clear separation between encryption pressure and stolen data pressure. Moved lateral movement into the enterprise expansion branch, annotated the missing MFA as a control weakness and preserved undisclosed mechanisms as U

Change Healthcare Case Synthesised Attack Tree



Simplified presentation view. Full model provided in Appendix F.

Change Healthcare Case-Synthesised Attack Tree Analysis

Key Interpretation

The root uses AND because the attacker required access, enterprise expansion, coercive impact and communication of the demand.

Initial access as strong evidence: attackers used compromised credentials to enter the Citrix Portal.

The method used to obtain those credentials remains unknown.

Encryption and stolen data form OR branches because either could create extortion pressure. Both occurred in this incident.

Confirmed control weakness

The Citrix portal did not require multifactor authentication

Remaining evidence gaps

Credential acquisition method: U

Persistence mechanism: U

Privilege escalation and lateral-movement
methods: U

Detailed data-exfiltration route: U

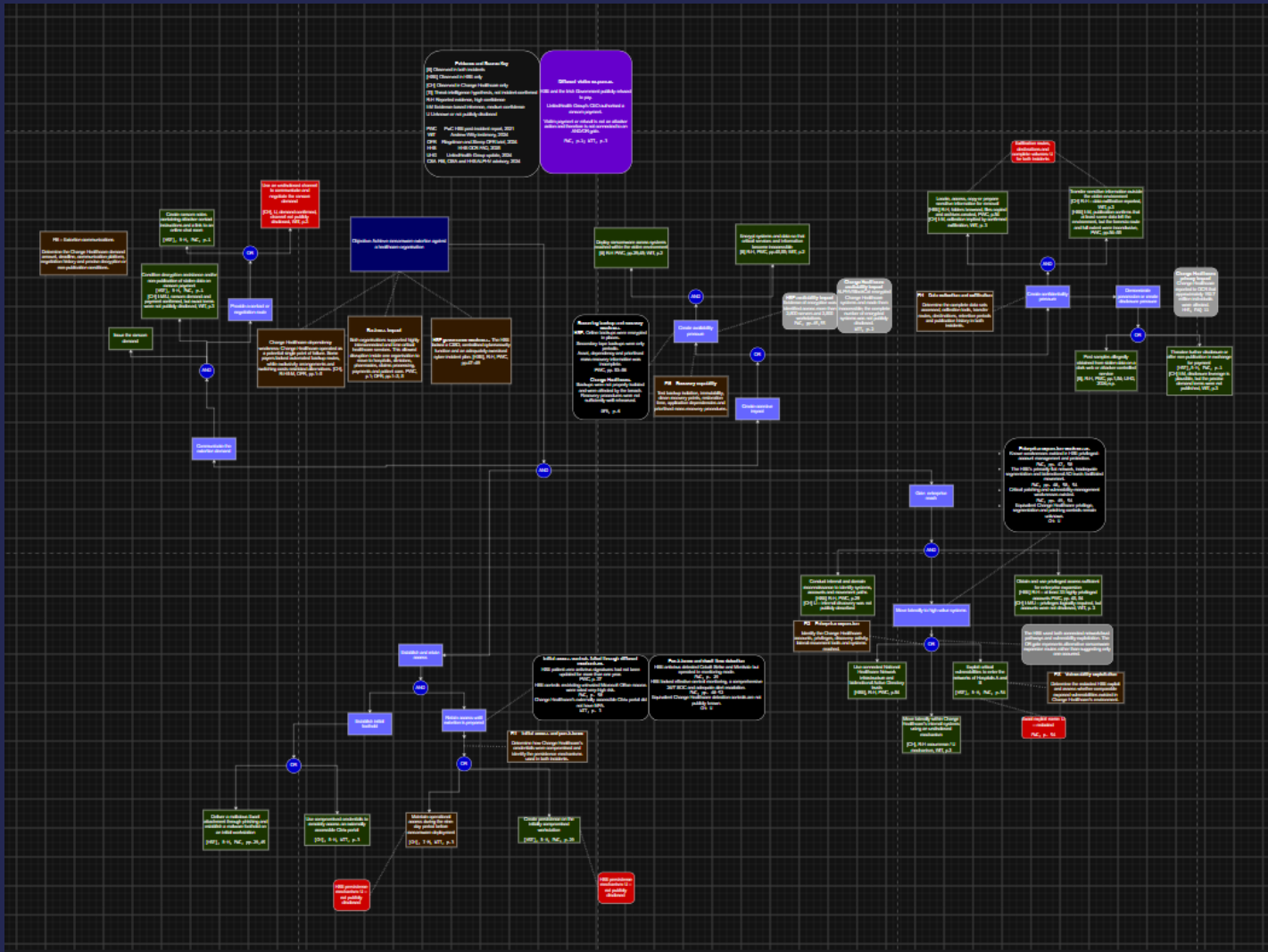
Key finding: Public evidence clearly establishes the initial entry and resulting impact, but provides limited details about the attacker's activity between those stages

Cross Incident Comparison

Attack Dimension	HSE, 2021	Change Healthcare, 2024	Cross incident conclusion
Initial access	Malicious Excel attachment delivered through phishing	Compromised credentials used to access a Citrix portal without MFA	Ransomware can begin through different entry routes, represented as OR alternatives
Enterprise expansion	AD reconnaissance, privileged accounts, trusted connections and vulnerability exploitation	Lateral movement and data theft reported, but detailed methods remain undisclosed	Enterprise access depends on identity, privilege and network reach
Coercive impact	Conti encryption combined with theft and publication of data	Ransomware combined with theft of personal and health information	Both incidents used availability and confidentiality pressure
Business exposure	Disruption across the national health service and connected hospitals	Disruption to claims, payments and pharmacy transactions across the healthcare sector	Healthcare dependencies increased the scale of downstream disruption
Evidence gaps	Persistence, hospital exploit and exfiltration mechanisms remain partly unknown or redacted	Credential acquisition and most post-access techniques remain unknown	The final model must distinguish reported actions from assumptions and competing hypothesis

Cross incident finding: Different initial access routes converged after entry. Both attackers expanded beyond the initial foothold and created extortion pressure through operational disruption and stolen data.

Final Synthesised Healthcare Ransomware Attack Tree



How to read the model

1. The root uses AND because extortion requires access, enterprise expansion, coercive impact and communication of a demand
2. Initial access uses OR branches to represent the different entry routes identified across the incidents
3. Enterprise expansion captures the common need to move beyond the initial foothold
4. Encryption and stolen data pressure form OR branches. Attackers may use either method or combine both

Evidence boundary

The model distinguishes reported evidence, evidence based inference and unknown mechanisms. It represents two incidents and remain preliminary.

Main conclusion

Different entry routes converged on the same downstream objective. Controls that prevent enterprise expansion can disrupt several ransomware pathways before attackers create extortion pressure.

Initial cross-incident model based on HSE and Change Healthcare. Full-size model provided in Appendix G.

Priority Risks and Recommendations

ID	Risk identified from the final tree	Priority	Recommended action
FI1	Phishing or compromised credentials provide initial access	Critical	Require phishing-resistant MFA for remote access, restrict untrusted macros and strengthen email filtering
FI2	Attackers maintain access without effective detection	Critical	Operate endpoint protection in blocking mode, centralise security logs and provide continuous monitoring with tested alert escalation
FI3	Compromised privileged accounts enable enterprise control	Critical	Implement privileged access management, separate administrator accounts, enforce admin MFA and apply least privilege
FI4	Flat or trusted networks enable lateral movement	High	Segment critical environments, restrict unnecessary AD trusts and monitor traffic between network zones
FI5	Encryption disrupts critical services and delays recovery	Critical	Maintain unalterable and offline backups, map critical dependencies and regularly test service-scale restoration
FI6	Stolen sensitive data creates additional extortion pressure	High	Inventory sensitive data, restrict bulk access, monitor unusual data transfers and rehearse breach response procedures

Immediate priorities: Strong identity controls, active security monitoring, protected privileged accounts and recoverable backups interrupt the greatest number of pathways

Recommendations assume a large, interconnected healthcare organisation handling critical services and sensitive health information. Not every weakness has been confirmed in both incidents.

Priority Areas for Further Investigation

Priority	Investigation question	Why it matters	Evidence required
1	How did the attackers obtain the Change Healthcare credentials? U	Confirms the initial-access pathway and the controls that failed	Identity-provider and Citrix logs, phishing reports and credential-exposure records
2	How did the attackers maintain access and avoid detection? U / I-M	Establishes whether monitoring or escalation failures extended the dwell time	Endpoint telemetry, SIEM alerts, host images and incident tickets
3	Which accounts, trusts or vulnerabilities enabled enterprise expansion? R-H / U	Identifies the main opportunities to stop privilege abuse and lateral movement	AD and privileged-access records, trust maps, vulnerability data and network logs
4	How and when did data exfiltration occur? I-M / U	Determines breach scope, notification duties and confidentiality risk	Firewall, proxy, DNS and cloud logs, file-access records and data-loss alerts
5	Could critical services and backups recover independently at scale? I-M	Tests whether recovery arrangements match healthcare service dependencies	Asset registers, dependency maps, backup configurations and restoration-test results

Next research stage: Analyse additional healthcare ransomware incidents to determine which branches represent recurring patterns and which remain specific to HSE or Change Healthcare

Executive Conclusion

Different initial-access routes produced the same result once attackers gained enterprise reach: critical service disruption combined with stolen data pressure.

1. Main finding

HSE was breached through a malicious attachment, while Change Healthcare was breached using compromised remote access credentials. These incidents then expanded within the enterprises, leading to ransomware deployment and data theft

3. Limitation and next step

The model draws from two publicly reported incidents. Redactions and incomplete disclosures leave several persistence, lateral-movement and exfiltration mechanisms unresolved. Additional cases should test and refine these branches.

2. Executive priority

Organisations should place importance on controls that prevent a local foothold from becoming an enterprise compromise:

- Strong remote access and privileged-account authentication
- Active endpoint monitoring and alert escalation
- Network segmentation and restricted trust relationships
- Unalterable backups and tested restoration of critical services

Executive decision: Direct early investment toward identity security, detection, containment and verified recovery because these controls interrupt several attack pathways.

References Incident Evidence

PricewaterhouseCoopers (PwC) 2021, *Conti cyber attack on the HSE: Independent post incident review*, Health Service Executive, 3 December, viewed 20 August 2026, https://about.hse.ie/api/v2/download-file/file_based_publications/conti_cyber_attack_on_the_hse_full_report.pdf/

Witty, A. 2024, 'Hacking America's health care: assessing the Change Healthcare cyber attack and what's next', testimony before the United States Senate Committee on Finance, 1 May, viewed 25 August 2026, https://www.finance.senate.gov/imo/media/doc/hacking_americas_health_care_assessing_the_change_healthcare_cyber_attack_and_whats_next.pdf

Fliegelman, A. and Stemp, D. 2024, *The cyberattack on Change Healthcare: lessons for financial stability*, OFR Brief no. 24-05, Office of Financial Research, 13 November, viewed 25 August 2026, <https://www.financialresearch.gov/briefs/files/OFRBrief-24-05-change-healthcare-cyberattack.pdf>

UnitedHealth Group 2024, 'UnitedHealth Group updates on Change Healthcare cyberattack', 22 April, viewed 25 August 2026, <https://www.unitedhealthgroup.com/newsroom/2024/2024-04-22-uhg-updates-on-change-healthcare-cyberattack.html>

U.S. Department of Health and Human Services, Office for Civil Rights 2025, 'Change Healthcare cybersecurity incident frequently asked questions', updated 14 March, viewed 25 August 2026 <https://www.hhs.gov/hipaa/for-professionals/special-topics/change-healthcare-cybersecurity-incident-frequently-asked-questions/index.html>

Mahn, A., Marron, J., Quinn, S. and Topper, D. (2021) *Getting Started with the NIST Cybersecurity Framework: A Quick Start Guide*. NIST Special Publication 1271. Gaithersburg, MD: National Institute of Standards and Technology. Available at: <https://doi.org/10.6028/NIST.SP.1271> (Accessed: 8 September 2026).

Software reference

JGraph Ltd 2026, *draw.io* [diagramming software], viewed 20 August 2026, <https://www.drawio.com/>.

OpenAI 2026a, *ChatGPT response to a prompt requesting an attack tree for the 2021 HSE Conti ransomware incident*, large language model output, 26 August, OpenAI, <https://chatgpt.com/>. Prompt and output reproduced in Appendix B.

OpenAI 2026b, *ChatGPT Astra response to a prompt requesting an attack tree for the 2024 Change Healthcare ransomware incident*, large language model output, 26 August, OpenAI, <https://chatgpt.com/>. Prompt and output reproduced in Appendix E.

References Framework, Guidance, and Tools

Frameworks and guidance

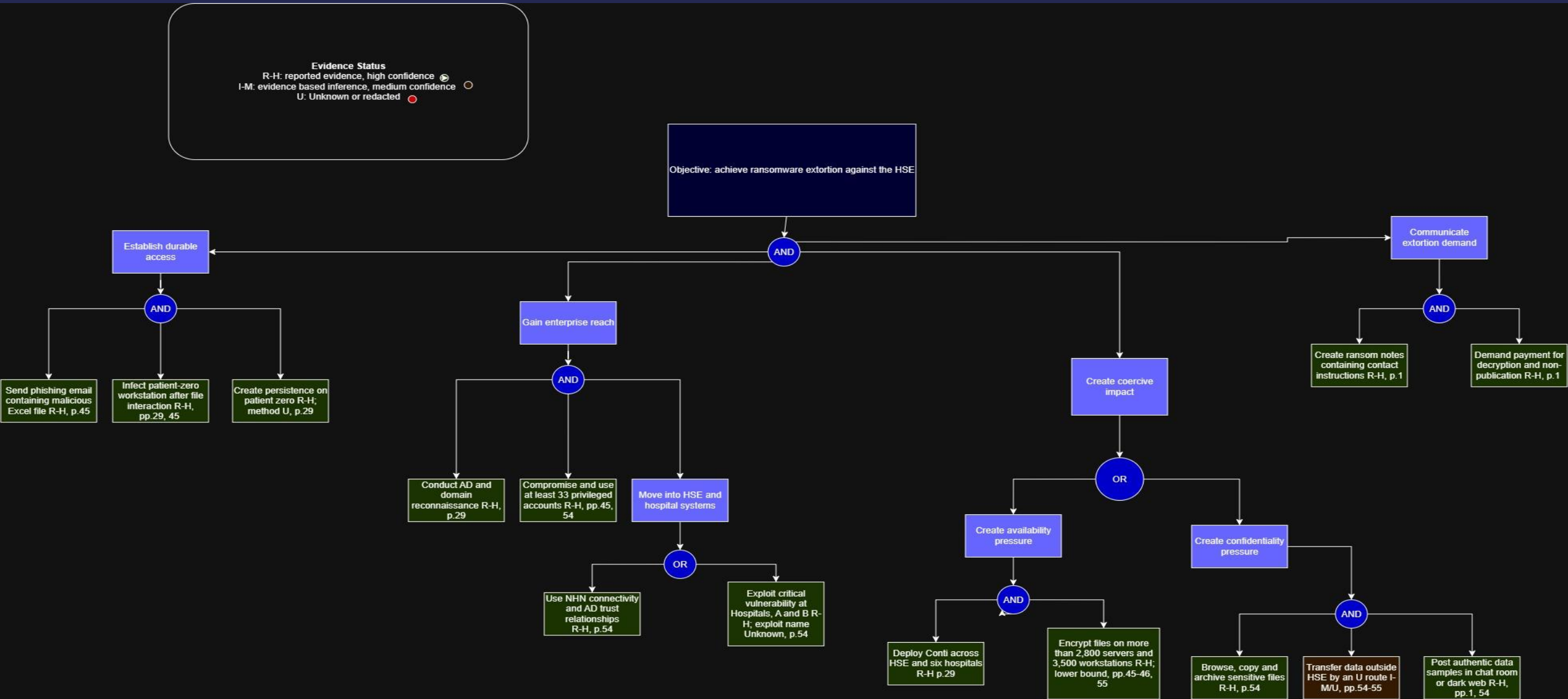
Australian Signals Directorate 2023, *Essential Eight maturity model*, Australian Cyber Security Centre, updated 27 November, viewed 23 August 2026, <https://www.cyber.gov.au/business-government/asds-cyber-security-frameworks/essential-eight/essential-eight-maturity-model>.

Cybersecurity and Infrastructure Security Agency, Federal Bureau of Investigation and U.S. Department of Health and Human Services 2024, *#StopRansomware: ALPHV Blackcat*, Cybersecurity Advisory AA23-353A, revised 27 February, viewed 24 August 2026, <https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-353a>.

Mahn, A., Marron, J., Quinn, S. and Topper, D. 2021, *Getting started with the NIST Cybersecurity Framework: a quick start guide*, NIST Special Publication 1271, National Institute of Standards and Technology, viewed 24 August 2026, <https://doi.org/10.6028/NIST.SP.1271>.

Schneier, B. 1999, 'Attack trees', *Dr. Dobbs's Journal*, vol. 24, no. 12, pp. 21–29, viewed 21 August 2026 https://www.schneier.com/academic/archives/1999/12/attack_trees.html

Appendix A: HSE Manual Attack Tree



Appendix B: HSE LLM Output

Appendix B1: Prompt

Tool: ChatGPT

Provider: OpenAI

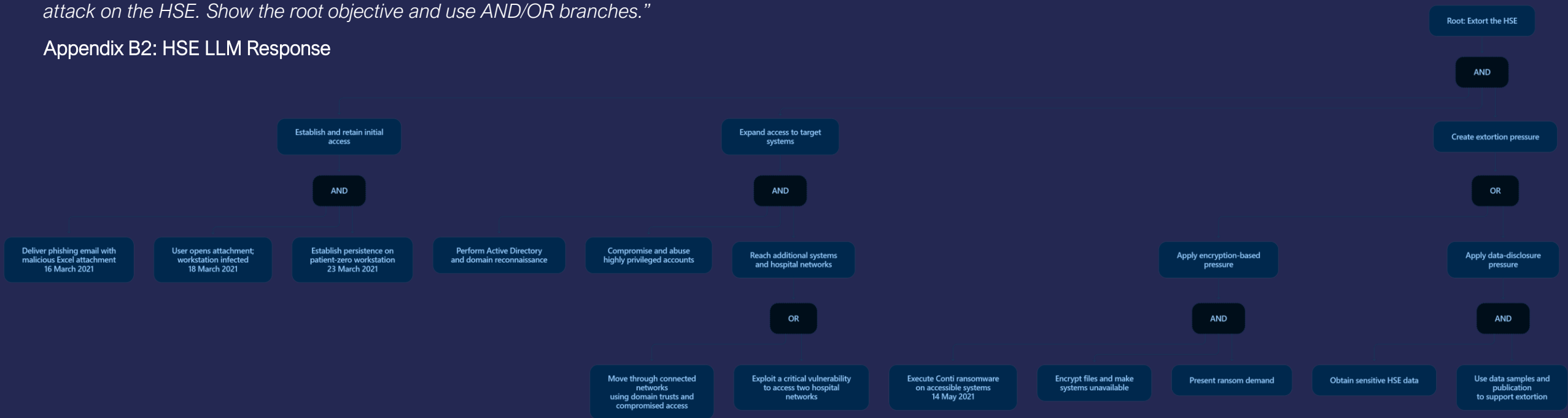
Date generated: 26 August 2026

Approach: Single prompt and response

Input: PwC HSE post-incident report

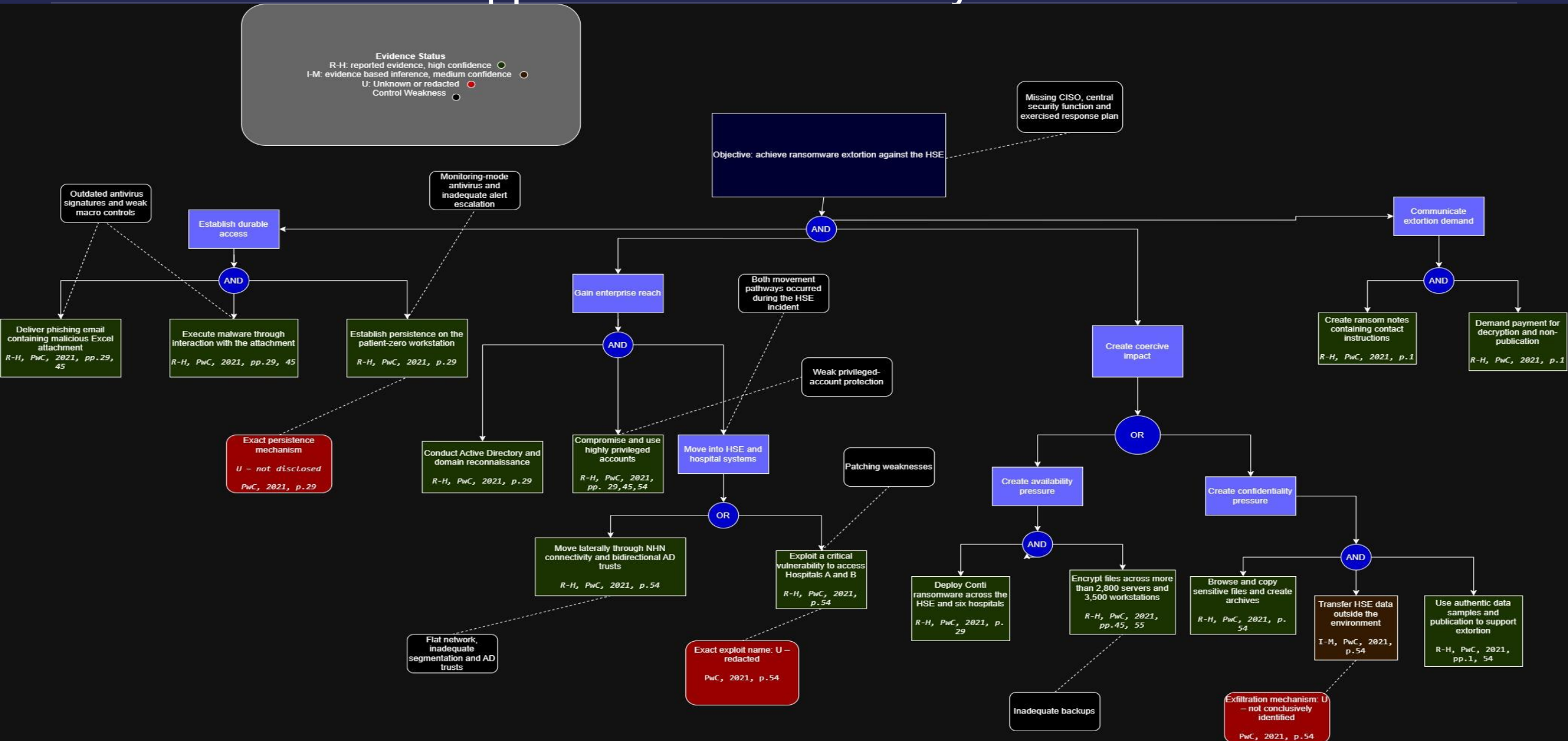
“Based on the attached PwC report, create an attack tree for the 2021 Conti ransomware attack on the HSE. Show the root objective and use AND/OR branches.”

Appendix B2: HSE LLM Response

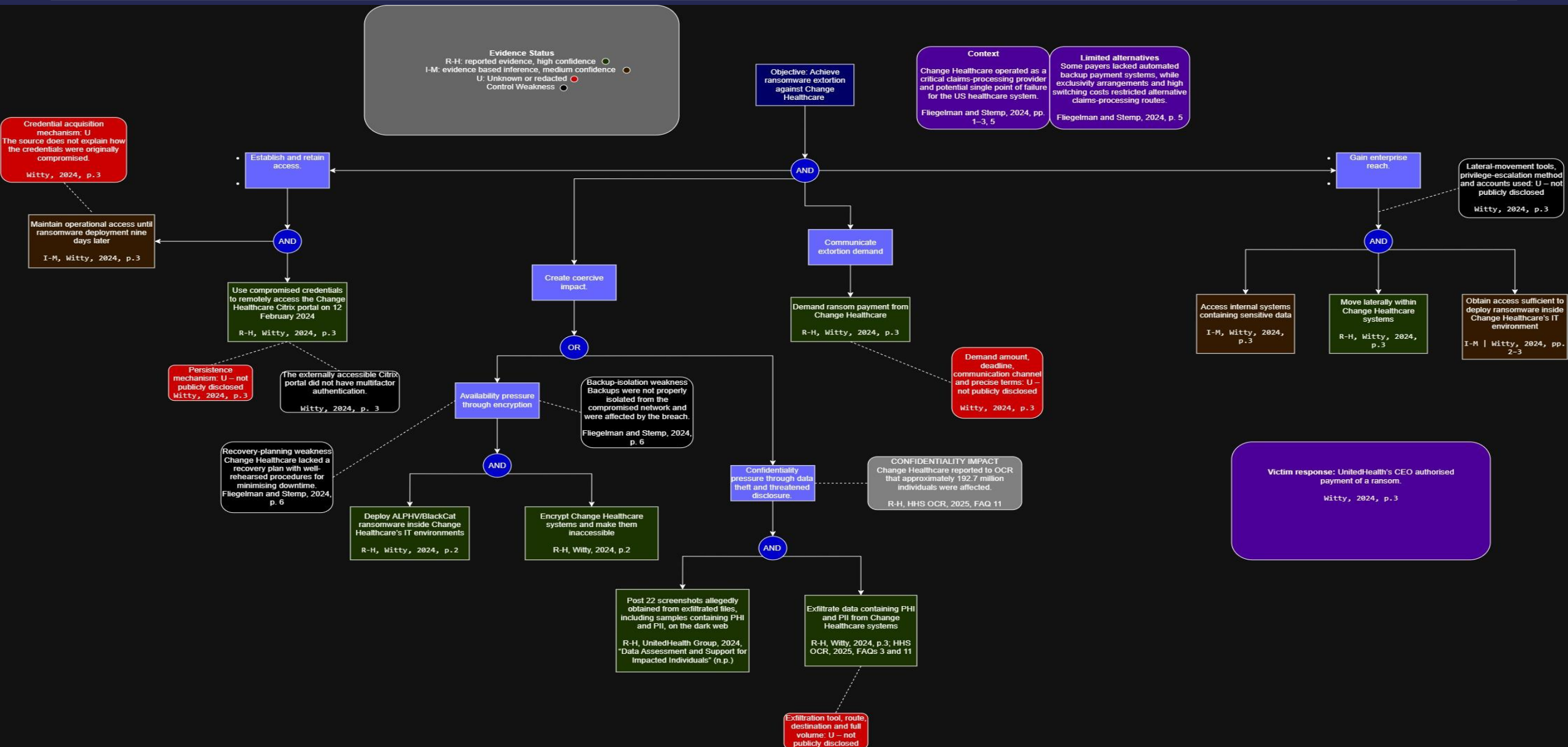


<https://drive.google.com/file/d/1CvcQLo2KiDT-reJvvr1AotKRfT42epE3/view?usp=sharing>

Appendix C: HSE Case Synthesis



Appendix D: Change Healthcare Manual Tree



Appendix E: Change Healthcare LLM Output

Appendix E1: Prompt

Tool: ChatGPT

Provider: OpenAI

Date generated: 26 September 2026

Approach: Single prompt and response

Prompt used:

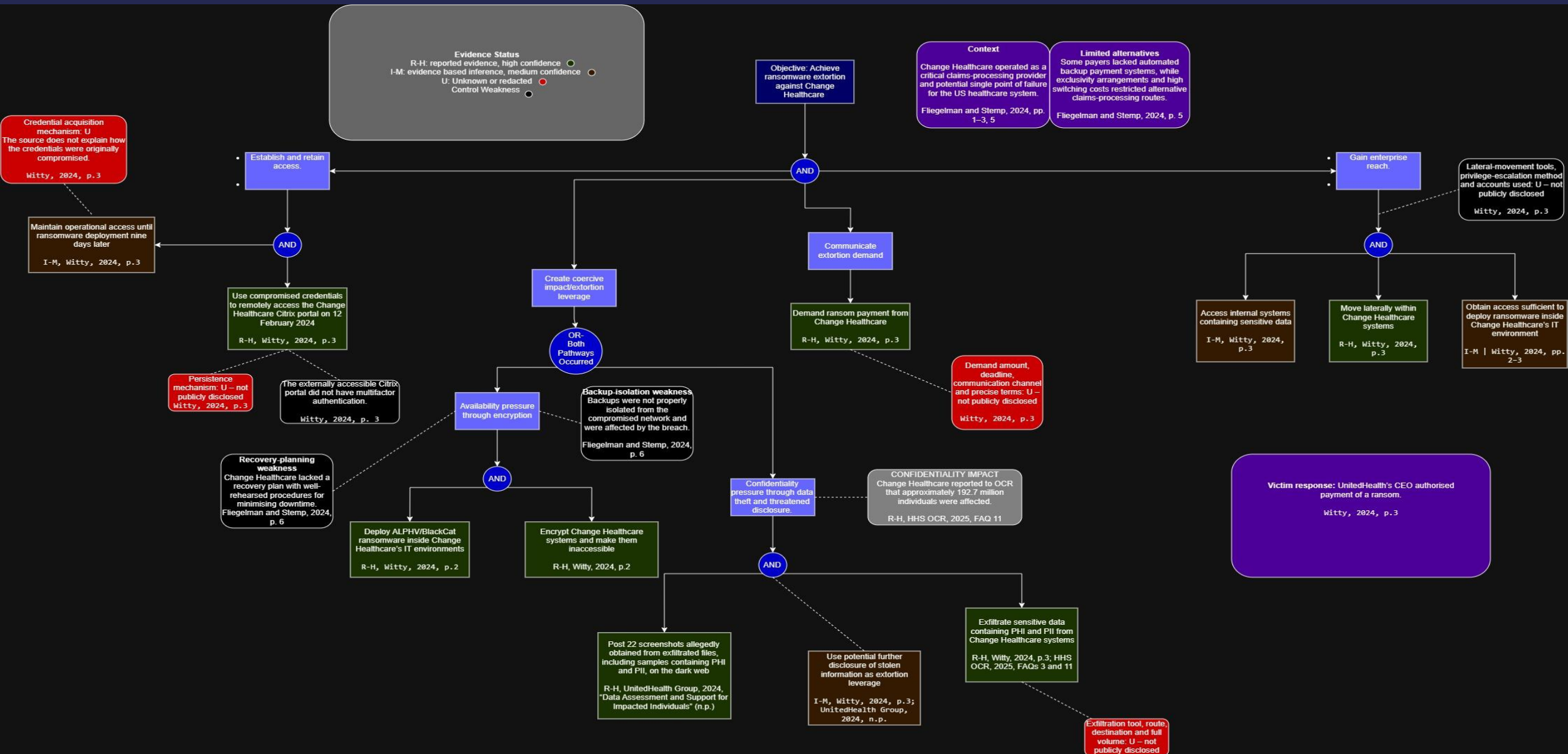
"Create an attack tree for the Change Healthcare, United States (2024) attack. Show the root objective and use AND/OR branches."

Appendix E3: Change Healthcare LLM response



https://drive.google.com/file/d/1QLfK1tXubo2P9SCv_tKxIS2CBG5WJXOY/view?usp=drive_link

Appendix F: Change Healthcare Case Synthesised Attack Tree



Appendix G: Final Synthesised Tree

